Security Compliance Automation using 

KIRO 2026

OVERVIEW

Apa saja yang bisa saya lakukan dengan KIRO

1. **Digital Twin**
   KIRO melakukan login SSO dan melakukan pengecekan seluruh Account di AWS (jika multiple account) dengan profil tertentu.

2. **Security Hub CSPM Collection**
   Pengumpulan hasil temuan yang ada di Security Hub CSPM yang memiliki banyak temuan yang menyebabkan terjadi pagination.

3. **AWS WAF WebACL Customization Rules**
   Melakukan custom WebACL Rules untuk menyesuaikan dengan kebutuhan bisnis.

4. **Workspace Creation**
   Mempercepat proses prompting berulang dengan workspace yang sudah dikonfigurasi.

5. **Autopilot with Kiro**
   Automasi penuh dengan mode autopilot untuk menjalankan task secara berurutan.

FEATURE 01

Digital Twin — AWS SSO Multi-Account

Login SSO dan pengecekan seluruh AWS Account secara otomatis

COMMANDS

```
# 1. Configure SSO session
aws configure sso

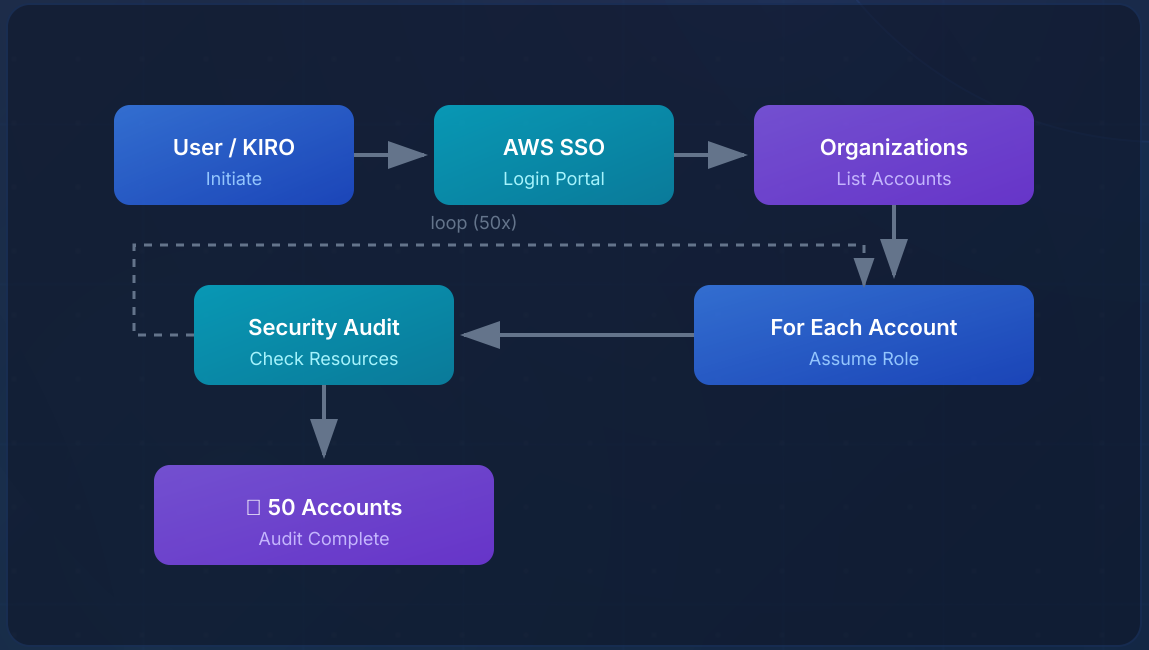
# 2. Login to SSO
aws sso login --profile security-audit

# 3. List all accounts in Organization
aws organizations list-accounts \
    --query 'Accounts[].{Id:Id,Name:Name,Status:Status}'

# 4. Iterate through accounts
for account in $(aws organizations list-accounts \
    --query 'Accounts[].Id' --output text); do
    echo "Checking account: $account"
    aws sts assume-role \
        --role-arn "arn:aws:iam::${account}:role/SecurityAuditRole" \
        --role-session-name "KiroAudit"
done

# Output: 50 accounts discovered
```

FLOW DIAGRAM



KIRO 2026

FEATURE 02

Security Hub CSPM — Bulk Finding Collection

Mengumpulkan 5000+ findings dengan pagination handling

COMMANDS & PROCESS

```
# 1. Get findings with pagination (max 100 per page)
aws securityhub get-findings \
    --filters '{"RecordState":[{"Value":"ACTIVE","Comparison":"EQUALS"}]}' \
    --max-items 100

# 2. Use NextToken for pagination loop
next_token=""
all_findings="[]"
while true; do
    response=$(aws securityhub get-findings \
        --filters '{"ComplianceStatus":[{"Value":"FAILED","Comparison":"EQUALS"}]}' \
        --max-items 100 \
        ${next_token:+--starting-token "$next_token"})
    findings=$(echo "$response" | jq '.Findings')
    all_findings=$(echo "$all_findings $findings" | jq -s 'add')
    next_token=$(echo "$response" | jq -r '.NextToken // empty')
    [[ -z "$next_token" ]] && break
done

# 3. Export to CSV
echo "$all_findings" | jq -r '.[] |
    [.Title, .Severity.Label, .Compliance.Status, .ProductName] |
    @csv' > security_hub_findings.csv

# Result: 5000 findings exported to CSV
```

Example Finding: [EC2.19] Security groups should not allow unrestricted access to ports with high risk

FLOW DIAGRAM



KIRO 2026

FEATURE 03

AWS WAF WebACL Customization Rules

Custom rules untuk kebutuhan bisnis tanpa mengorbankan keamanan

COMMANDS

```
# 1. List WebACLs
aws wafv2 list-web-acls --scope REGIONAL

# 2. Get WebACL Rules
aws wafv2 get-web-acl \
    --name "production-waf" \
    --scope REGIONAL \
    --id "xxxxxxxx-xxxx-xxxx-xxxx-xxxxxxxxxxxx"

# 3. Check sampled requests (blocked)
aws wafv2 get-sampled-requests \
    --web-acl-arn "arn:aws:wafv2:..." \
    --rule-metric-name "AWS-AWSManagedRulesCommonRuleSet" \
    --scope REGIONAL \
    --time-window '{"StartTime":"2026-10-01","EndTime":"2026-10-16"}'

# 4. Add exclusion rule for legitimate traffic
aws wafv2 update-web-acl \
    --name "production-waf" \
    --scope REGIONAL \
    --id "xxx" --lock-token "xxx" \
    --rules '[...]' \
    --default-action '{"Allow":{}}'

# False positive resolved, business traffic allowed
```

FLOW DIAGRAM



KIRO 2026

FEATURE 04

Workspace Creation

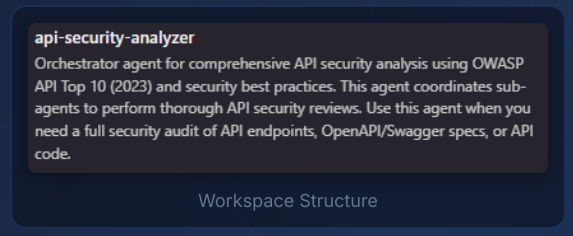
Mempercepat proses prompting berulang dengan konfigurasi workspace

SETUP PROCESS

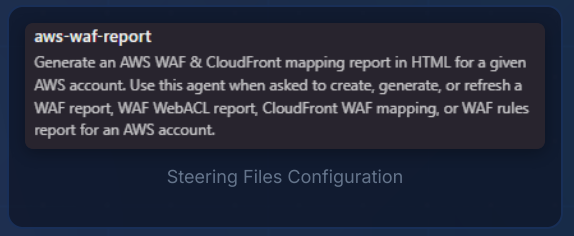
```
# 1. Create workspace folder structure
mkdir -p security-workspace/.kiro/steering
mkdir -p security-workspace/.kiro/agents
mkdir -p security-workspace/.kiro/hooks

# 2. Create steering files for common prompts
cat > .kiro/steering/security-audit.md << 'EOF'
# Security Audit Template
Always include:
- AWS account context
- Compliance framework (SOC2, HIPAA, PCI-DSS)
- Output format (JSON, CSV, markdown)
EOF
```

SCREENSHOT PREVIEW



Workspace Structure



Steering Files Configuration

FLOW DIAGRAM



KIRO 2026

FEATURE 05

Autopilot with Kiro

Automasi penuh dengan kombinasi Global Read-Only + Workspace + Auto Approve

Global Read-Only Account

Akses read-only ke seluruh AWS accounts melalui Organization dengan SecurityAudit role. Aman untuk audit tanpa risiko modifikasi.

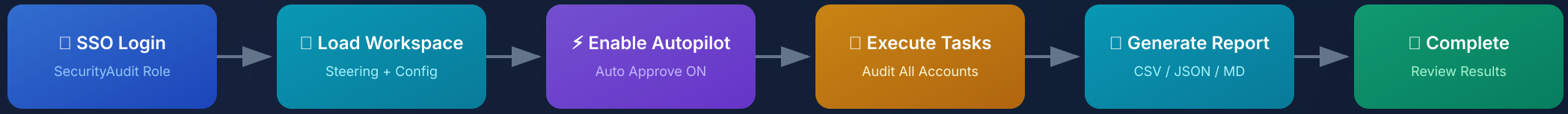
Pre-configured Workspace

Workspace dengan steering files, MCP config, dan agents yang sudah disiapkan untuk security compliance tasks.

Auto Accept / Approve

Mode autopilot di Kiro yang secara otomatis menyetujui safe operations tanpa perlu konfirmasi manual.

COMPLETE AUTOPILOT FLOW



End-to-end automation: 50 accounts audited in minutes, not hours

KIRO 2026

TERIMA KASIH

Security Compliance Automation using KIRO